

植基於超增序列的單伺服器私密資訊擷取機制

陳俊華^{1&2}

¹ 中興大學資訊科學所 台中市國光路 250 號

² 建國技術學院電子系 彰化市介壽北路 1 號

godsons@ckit.edu.tw

摘要

在電子商務(e-commerce)的環境中要保護使用者的隱私權,使伺服器也無法得知使用者所擷取的資訊為何,一般認為這是不可能的。直到私密的資訊擷取(Private Information Retrieval: PIR)的問題被提出並加以解決。一個私密的資訊擷取機制允許使用者從線上伺服器的資料庫中擷取資料項,但卻使伺服器無法得知使用者查詢的是何項資料。PIR 自 1995 年由 Chor 等人提出後受到相當的重視,後續也有不少相關的研究。

在本論文中,我們提出一個植基於超增序列(Superincreasing Sequence)的單伺服器的私密資訊擷取(PIR)機制,其安全性為資訊理論上的安全。相對於之前其它的 PIR 機制,我們所提出的機制較簡單且更適用於電子商務的環境中。另外,本篇論文也包含安全性的證明(provable secure)及與其他 PIR 機制的比較。

關鍵詞：電子商務,使用者隱私權保護,私密的資訊擷取,超增序列

一、導論

在電子商務中線上查詢、擷取有價資訊的環境中,有許多的情況使用者(或顧客)的隱私性需要被保護;換句話說,當使用者線上查詢付費資訊時,會希望資料庫伺服器(Database Server)並不知道使用者所查詢的是哪幾筆資訊;以下茲就幾例加以說明之[12]:

(一) 專利資料庫:

如果專利資料庫的伺服器知道,線上使用者查詢的意欲為何,這將導致許多的問題。我們想像若有一個科學家發現了一個重要的公式,例如「 $H_2 + O_2 \Rightarrow H_2O$ 」,很自然的他想去申請專利(這發現可用於沙漠中造水等許多有市場價值的應用)。但首先他需要去線上專利資料庫查詢,是否已存在這樣的專利或類似的專利。但此時該專利資料庫伺服器管理者,已於該科學家查詢時得知:該科學家有將「 $H_2 + O_2 \Rightarrow H_2O$ 」申請為專利的意圖,這立刻給該伺服器管理者有以下想法:(i)知道該科學家正在作這方面的研究(ii)「 $H_2 + O_2 \Rightarrow H_2O$ 」可能是新的發明,為什麼不能比該科學家早一步申請該專利。以上兩項想法都是非常有價值的情報,該伺服器管理者,大可待價而沽、大發利市了。由此例我們知道,使用者查詢的隱私權應當被保護,以免產生以上不合理的現象。

(二) 製藥資料庫:

製藥公司為開發新藥必需去搜集關於藥品的基本成份和它們的特性,通常會有專門的公司提供製藥的資料庫以供查詢。合成一種新藥的過程需要從該資料庫取得該數種基本成份的資訊。為了讓製造新藥的計畫不致外洩,製藥公司往往購買下整個製藥的資料,如果這種線上資料庫的查詢能作到使用者隱私權保護(只知該使用者上線查詢,卻不知使用者所查詢的是哪幾筆資料),則可省去購買整個資料庫的大筆費用,只需購買所需要的幾種基本成份的線上資訊即可。

(三) 線上有價數位商品：

有些數位商品如電子書、音樂檔(例：MP3)、影像檔及視訊影片檔等，使用者直接可由線上查詢、擷取。可能會有不少的使用者會希望在線上購買這些數位產品時保持其隱私性。

有一家最大型的線上多媒體公司宣稱其擁有百萬客戶的資料及其購買嗜好，這也被當成該公司的重要資產。這可能成為一個商場的交易，客戶的資料及其購買嗜好會在未經使用者允許的情形下賣給其它公司[12](由於公司破產或老闆結束營業)；這是不太合理的現象，但也更凸顯出電子商務環境中使用使用者隱私權保護機制的重要性。於下一段落中我們將介紹最基本的雙伺服器私密資訊擷取機制，以便使讀者了解如何做到使用者隱私權保護。

二、基本雙伺服器私密資訊擷取機制

本段落詳細說明先驅者 Chor 等人於[1][2]中所提出之最基本私密資訊擷取機制—雙伺服器私密資訊擷取機制(two-server PIR scheme)，藉著向兩個伺服器作查詢而隱藏了真正查詢的意圖，而藉著重建兩個伺服器所傳回的結果而得到真正使用者所欲查詢的結果。於本段落中我們整理出 k 伺服器 PIR 機制的相關觀念、定義，並以實例說明雙伺服器(k=2)私密資訊擷取機制；最後我們簡單證明該機制的正確性。

(一) 預備觀念：

- n** 索引 $i \in [n] \equiv \{1, 2, 3, \dots, n\}$ (i 是使用者有興趣的位元， n 是資料庫的位元數)
- n** $X \equiv x_1 \dots x_n$ 一個包含於 $\{0, 1\}^n$ 的字串，代表一資料庫
- n** 隨機輸入 r 其長度為 L_{rnd}
- n** 使用者向 k 個伺服器產生 k 個長度為 L_q 的查詢： $Q_1(i, r), \dots, Q_k(i, r)$
- n** k 個伺服器根據於資料庫 X 的全部內容，回應長度為 L_a 的 $A_1, \dots, A_k$

- n** 使用者依據 $A_1, \dots, A_k$ 的值，以重建函數 R 重建有興趣的位元 x_i

(二) k 伺服器 PIR 機制的正式定義：

定義：若資料庫長度為 n ，一個 k 伺服器 PIR 機制(**k-server PIR Scheme**)包含：

- n** k 個查詢函數 $Q_1, \dots, Q_k$ ：
 $[n] \times \{0, 1\}^{L_{rnd}} \rightarrow \{0, 1\}^{L_q}$
- n** k 個回應函數， $A_1, \dots, A_k$ ：
 $\{0, 1\}^n \times \{0, 1\}^{L_q} \rightarrow \{0, 1\}^{L_a}$
- n** 一個重建函數 R ：
 $[n] \times \{0, 1\}^n \times \{0, 1\}^{L_{rnd}} \times (\{0, 1\}^{L_a})^k \rightarrow \{0, 1\}$

以上函數需滿足正確性及隱私性

正確性代表經過使用者重建函數的計算後，確實得到使用者有興趣的位元值 x_i

隱私性代表經過以上程序處理後，對於資料庫伺服器來說，使用者有興趣的位元是 x_i 或是 x_j ($i \neq j$)，其機率是完全一樣的(也就是能保護使用者查詢的隱私權)

正確性：For every $x \in \{0, 1\}^n$,

$$i \in [n], \text{ and } r \in \{0, 1\}^{L_{rnd}} \rightarrow R(i, r, A_1(X, Q_1(i, r)), \dots, A_k(X, Q_k(i, r))) = x_i$$

隱私性：For every $i, j \in [n]$,

$$s \in [k], \text{ and } q \in \{0, 1\}^{L_q} \rightarrow \Pr(Q_s(i, r) = q) = \Pr(Q_s(j, r) = q)$$

其中隨機輸入 $r \in \{0, 1\}^{L_{rnd}}$ 是以均勻分佈的機率隨機選取

(三) 會用到的表示法：

- n** U ：使用者
- n** $SRV_1, \dots, SRV_k$ ： k 個伺服器
- n** $X \equiv x_1 \dots x_n$ 一個包含於 $\{0, 1\}^n$ 的字串，代表 k 個伺服器上相同的資料庫
- n** i ：代表使用者有興趣的位元索引
- n** $[m] \equiv \{1, 2, \dots, m\}$
- n** 對於一個集合 S 及一個元素 a
 $S \oplus a \equiv S \setminus \{a\} \quad \text{if } a \notin S$
 $\equiv S \cup \{a\} \quad \text{if } a \in S$

裡不再贅述。

雙伺服器 PIR 機制的執行步驟如下：

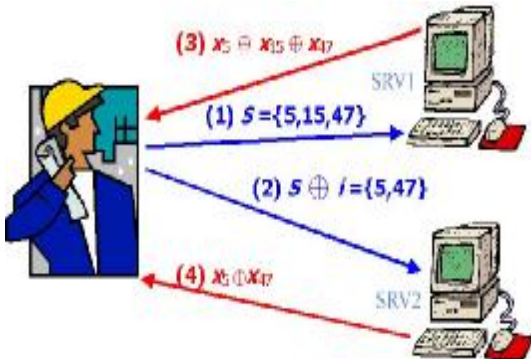
1. 使用者隨機選取一個集合 $S \subseteq [n]$
2. 使用者將 S 送給 SRV1 並且將 $S \oplus i$ 送給 SRV2
3. 每一個伺服器回應一個位元，其值是由 Exclusive OR 所有位元值屬於 S 或屬於 $S \oplus i$ (SRV1 回應 $\bigoplus_{j \in S} x_j$; SRV2 回應 $\bigoplus_{j \in S \oplus i} x_j$)
4. 使用者 Exclusive OR SRV1 回應及 SRV2 回應的值則可萃取出他想查詢的位元值 x_i

雙伺服器 PIR 機制的舉例及簡單證明如下：

使用者隨機選取 $S = \{5, 15, 47\}$

(假定 $n=10000$, index $i = 15$,

$S \oplus i = \{5, 47\}$)



使用者計算想得到的位元 x_i

$= (\text{SRV1 的回應}) \oplus (\text{SRV2 的回應})$

$$= (x_5 \oplus x_{15} \oplus x_{47}) \oplus (x_5 \oplus x_{47})$$

$$= (x_5 \oplus x_5) \oplus (x_{47} \oplus x_{47}) \oplus x_{15}$$

$$= 0 \oplus 0 \oplus x_{15}$$

$$= x_{15}$$

$$(\oplus x \oplus y = y \oplus x)$$

$$x \oplus (y \oplus z) = (x \oplus y) \oplus z = x \oplus y \oplus z$$

$$x_i \oplus 0 = 0 \oplus x_i = x_i$$

以上所討論的機制是雙伺服器私密資訊擷取機制；至於多伺服器($k \geq 2$)的 PIR 機制可參考[1][2]中詳細的闡釋、證明，這

三、相關研究回顧

一種衡量 PIR 機制的方法為萃取一個位元所需的傳輸複雜度(communication complexity)，Chor 等人已於[2]中證明：單伺服器 PIR 機制其所需的傳輸複雜度為 $O(n)$ ：相當於 download 整個資料庫。雖然可藉著 k 伺服器的 PIR 機制($k \geq 2$)來降低傳輸複雜度，從原來只有一個伺服器要達到 PIR 的 $O(n)$ ，降至 $O(n^{1/k})$ 。但當 database 的 size 非常大時這仍有不小的 overhead；因此有些關於 PIR 的後續研究上[4-7]，都著眼於如何降低其複雜度。

Andris 於[4]證明 k 伺服器的 PIR 機制($k \geq 2$)其傳輸複雜度降為 $O(n^{1/(2k-1)})$ 。Yael Gertner 等人於[7]中提出一個新的 PIR 機制(scheme)，除了原來的資料庫伺服器外，使用多個輔助的伺服器，仍能保持原先 PIR 機制的理論安全性(Information Theoretic Security)；且使用者對資料庫伺服器線上查詢時其傳輸複雜度只需 $O(1)$ ，此機制的優點為不需複製相同資料庫到多個伺服器上，減少了分散式資料庫系統管理上的負擔。但其缺點是此機制所用的伺服器數目是原先 PIR 機制[1][2]的兩倍；且這些輔助伺服器在建置(set up)階段，計算及傳輸所需的複雜度仍高達 $O(n)$ 。

Chor 於[9]中提出 Computational PIR(CPIR)的觀念，降低其在安全性的要求為計算上的安全(Computational Security)，以別於之前的 PIR 均為資訊理論上的安全 (Information Theoretic PIR)。Chor 等人提出兩個資料庫伺服器的 Computational PIR(CPIR)機制，其傳輸複雜度(Communication Complexity)為 $O(n^\epsilon)$ ，對任何的 $\epsilon > 0$ 。Cachin 於[5]中提出改進 CPIR 的機制使其傳輸複雜度降為 $O(k)$ *

$O(\log n)$ ，其中 k 為所選定的機密值；此篇論文採用一個新的安全性假定 Φ -Hiding Assumption，有許多理論和證明的的工作，顯得其機制較複雜、較理論；且其每次查詢一個位元的資料，資料庫伺服器都至少要作 n 個乘冪(exp)及 n 個除餘(mod)的運算，才能將回應給使用者的值計算出來，資料庫伺服器的負擔相當重。我們認為在電子商務的環境中，伺服器能快速回應使用者查詢的重要性，不下於較低的傳輸複雜度。

在多伺服器的機制中(無論是 PIR 或 CPIR)，都有一個安全性的問題亦即伺服器共謀的問題，不論在 PIR 或 CPIR 的機制中若所有伺服器共謀，在收到使用者對 k 個伺服器的查詢資訊後，將此 k 個訊息比對後可得到使用者想查的是資料庫哪一筆資訊，這代表所有伺服器共謀將破解 PIR 或 CPIR 保護使用者隱私權的安全機制。因此 Chor 等人在[2]中，乾脆將伺服器不能共謀作為此安全機制的先決條件。在多伺服器的機制中還有一個問題，因為最後使用者所要得到的資訊，是由所有伺服器的回應計算而得，因此若有伺服器回應的訊息若是錯誤的或無法回應，將造成使用者最後查詢結果的錯誤。有以下兩種情況將產生伺服器回應的問題：(1)惡意的伺服器，故意回應錯誤的訊息。(2)因伺服器當機、網路連線中斷或擁塞造成伺服器無法回應訊息。因此 Beimel 等人於[3]中提出強韌的 PIR 機制(Robust PIR Scheme)以解決以上問題。此篇論文提出一個 k -out-of- L PIR 機制，亦即只要在 L 個伺服器中只要有 k 個伺服器能回應訊息且回應的訊息是正確的，就足以正確的計算出使用者所欲查詢、擷取的資訊。此篇論文所提出的機制雖然是強韌的(Robust)，但其付出的代價就是要用到更多的伺服器($L > k$)。Yang 等人於[10][11]中針對相同的問題提出具容錯能力的(fault tolerance) PIR 機制，並在實際的多伺服器資料庫($k=2\sim 11$)

中作一些簡單的實驗。

根據以上相關的研究顯示，PIR 的研究確實對電子商務環境中使用隱私權的保護有相當關鍵的突破。但從以上研究的分析中我們發現多伺服器的 PIR 機制其伺服器管理的負擔極大，且容易有安全上的漏洞，這會使得 PIR 機制在實務上變得較不可行。因此，我們於本篇論文中提出一個實務上較可行的單伺服器私密資訊擷取(PIR)機制。

四、我們所提出的單伺服器私密資訊擷取機制

(一) 預備觀念

- n $i \in [n] \equiv \{1, 2, 3, \dots, n\}$ (i 是使用者有興趣的位元編號， n 是資料庫的位元數)
- n $X \equiv x_1 \dots x_n$ 一個包含於 $\{0, 1\}^n$ 的字串，代表一資料庫
- n 使用者以 $Q(i)$ 產生查詢並送給資料庫伺服器
- n 資料庫伺服器根據於資料庫 X 的全部內容，以 $A(X, Q(i))$ 產生回應給使用者
- n 使用者以 $R(i, Q(i), A(X, Q(i)))$ 重建有興趣的位元值 x_i
- n 迷袋問題(Knapsack Problem)：指在給定的自然序列 $B = (b_1, b_2, \dots, b_n)$ 及一數 S 是否存在一子序列 $B' \subseteq B$ ，其中 $B' = (b'_1, \dots, b'_m)$ ，使得 $\sum_{i=1}^m b'_i = S$ 。這個問題已被證實是一個 NP-Complete 問題[8]。但並非所有的迷袋問題都是 NP-Complete 問題，在 B 為某些特定的序列的情況下(如超增序列)，迷袋問題成為易解的問題。
- n 超增序列(Superincreasing Sequence) 遞增序列 $B = (b_1, b_2, \dots, b_n)$ ，如果滿足下面的條件，就稱 B 為超增序列：

$$b_j > \sum_{i=1}^{j-1} b_i, j > 1$$
 若 B 為滿足上述定義的序列，且向量 $X = (x_1, \dots, x_n), x_i \in \{0, 1\}$ ，使得

$S = X \times B^T = \sum_{i=1}^n b_i x_i$ ，則由下列的演算法，在已知 S 及 B 的情況下很容易求出 X 。

n 超增序列演算法：

假定 $M = (m_1, m_2, \dots, m_n)$ ， $m_i \in \{0, 1\}$

For $i := n$ downto 1 do

Begin

If $S \geq b_i$ then $m_i := 1$

else $m_i := 0$;

$S := S - (b_i \times m_i)$;

End

If $S = 0$ then $X := M$

else “no solution exists”

(二) 單伺服器私密資訊擷取機制的定義

單伺服器的私密資訊擷取機制，對於大小為 n 個位元的資料庫包含一個查詢函數 $Q(i)$ ，一個回應函數 $A(Q(i))$ ，和一個重建函數

$R(i, Q(i), A(X, Q(i)))$

這些函數 (Q, A, R) 必須滿足以下特性：

正確性： For every $X \in \{0, 1\}^n$,

$i \in [n] \Rightarrow$

$R(i, Q(i), A(X, Q(i))) = x_i$

隱私性： For every $i, j \in [n] \Rightarrow$

$\Pr(Q(i) = q) = \Pr(Q(j) = q)$

(三) 機制的描述

1. 前置處理：

(1) 使用者隨機選取一個超增序列 $B =$

$(b_1, b_2, \dots, b_n)$ ，及兩整數 W, M 滿足：

$M > \sum_{i=1}^n b_i$ 且 $\gcd(W, M) = 1$

(2) 使用者將超增序列轉換成擬亂序列

$A = (a_1, a_2, \dots, a_n)$ ，其中 a_i 滿足

$a_i = (b_i \times W) \bmod M$

(3) 使用者將扮演類似公開金鑰的角色的

序列 A 連同使用者 ID 上傳給資料庫伺服器，以作為一段時期保護使用者隱私權之用。

2. 查詢時的處理：

(1) 使用者向資料庫伺服器傳遞使用者

ID，以表達欲查詢的意願；換句話說

$Q(i)$ 就是使用者 ID

(2) 資料庫伺服器計算 $A(X, Q(i))$ 的結果

並將其值傳回給使用者

(a) 伺服器依據使用者 ID 找出對應的

序列 $A = (a_1, a_2, \dots, a_n)$

(b) 計算 $S' = \sum_{i=1}^n a_i x_i$

(x_i 代表資料庫 X 編號 i 的位元值)

(c) $A(X, Q(i)) \leftarrow S'$

3. 使用者藉著計算 $R(i, Q(i), A(X, Q(i)))$ 的

值，可萃取出所欲查詢的位元值 x_i

(1) 根據 $A(X, Q(i)) : S'$ 及前置處理選取的

W, M 來計算 $S : \sum_{i=1}^n b_i x_i$

$S = (S' \times W^{-1}) \bmod M$

(2) 根據 i 值及前面所述的超增序列演算

法可萃取出 x_i 的值

雖然我們所提出的機制每次查詢可得到一個位元的值，像其他的 PIR 機制一樣；但 Chor 等人已證明[1]這是可以推廣至一個區塊(亦即一筆紀錄)的。

五、 機制正確性及安全性的證明

定理：我們所提出的私密資訊擷取機制是單伺服器的私密資訊擷取機制；並且在保護使用者的隱私權上具有資訊理論上的安全性。

證明：

1. 符合單伺服器 PIR 機制的定義形式：

在我們的機制中我們擁有一個查詢函數 $Q(i)$ ，一個回應函數 $A(Q(i))$ 和一個重建函數 $R(i, Q(i), A(X, Q(i)))$ ；因而符合單伺服器 PIR 機制的定義形式。

2. 滿足正確性：

因為使用者是以收到的 S' 來乘以 W^{-1} 並 $\bmod M$ 來求得超增序列 S

$$\begin{aligned}
&= (S' \times W^{-1}) \bmod M \\
&= (\sum_{i=1}^n b_i x_i W W^{-1}) \bmod M \\
&\quad (\because a_i = (b_i \times W) \bmod M) \\
&= (\sum_{i=1}^n b_i x_i) \bmod M \\
&= S
\end{aligned}$$

我們再依據超增序列的特性及其演算
我們可萃取出正確的 x_i 位元值。

3. 滿足隱私性：(資訊理論上的安全性)

由於 $Q(i)$ 的值為使用者 ID 值，因此
 $Q(i)$ 的值與 i 的值是完全不相關。

$\therefore$ For every $i, j \in [n] \quad \hat{e}$

$$\Pr(Q(i) = q) = \Pr(Q(j) = q)$$

並且資料庫伺服器僅從使用者得到與
 i 的值完全無關的使用者 ID 值，之後
判斷資料庫的每一個位元值是否為 1
以決定是否將 a_i 加總至 S' ，亦即資
料庫中的每個位元均以完全相同的方式
對待，所以完全不可能洩漏出 i 的
值；因此在保護使用者隱私權上具有
資訊理論上的安全性。

綜合以上證明，我們可說我們的私密資訊擷
取機制是具有資訊理論上的安全性單伺服
器私密資訊擷取機制；以上定理得證。

六、 討論

誠如我們於段落三相關研究回顧中所提
及的，在 k 伺服器的 PIR 機制中對於伺服器
的管理有極大的負擔，既要保持伺服器上資
料庫的一致性，更要避免其共謀；因此在電
子商務的環境中可行性並不高。我們所提出
的機制為單伺服器 PIR 機制，且我們的機制
於每次使用者查詢時資料庫伺服器只需作 n 次
加法運算比[5](需作 n 次乘幕及 n 次除餘)的
機制簡單許多，因此可行性較高；我們將相
關的 PIR 機制的比較整理如下表。

表 一：本論文的單伺服器 PIR 機制
與其它 PIR 機制的比較

比較 機制	安全性	使用單伺 服器或 多伺服器	實際 可行性
[1,2]中的 PIR 機制	資訊理論上 的安全性	k 伺服器	低
[3]中的 Robust PIR 機制	資訊理論上 的安全性	L 伺服器 ($L > k$)	低
[5]中的 CPIR 機制	計算上的 安全性	單伺服器	中
植基於超增 序列的 單伺 服器機制	資訊理論上 的安全性	單伺服器	高

七、 結論

在本篇論文中我們提出在電子商務環
境中較具有可行性之植基於超增序列的單
伺服器的私密資訊擷取機制。此機制避免
了管理多伺服器的龐大負擔(包含了使多
個資料庫一致及避免多伺服器的共謀);且
具有資訊理論上的安全性。

參考文獻

- [1] Benny Chor, Oded Goldreich, Eyal Kushilevitz and Madhu Sudan. Private Information Retrieval. *Proc. of the 36th IEEE Symposium on Foundations of Computer Science (FOCS)36th*, pp. 41-50, 1995.
- [2] Benny Chor, Oded Goldreich, Eyal Kushilevitz and Madhu Sudan. Private Information Retrieval. *Journal of ACM*, 45:965-981, 1998.
- [3] A. Beimel and Y. Stahl. Robust Information-Theoretic Private Information Retrieval. *Proc. of the 3rd Conference on Security in Communication Networks*, vol. 2576 of

- Lecture Notes in Computer Science*, pp. 326-341, 2002.
- [4] Andris Ambainis. Upper bound on the communication complexity of private information retrieval. *Proc. of 24th ICALP 97, Springer, Lecture Notes in Computer Science*, vol. 1256, pp. 401-407, 1997.
 - [5] Christian Cachin, Silvio Micali, and Markus Stadler. Computationally Private Information Retrieval With poly-logarithmic Communication. *Eurocrypt 99, Vol. 1592 of Lecture Notes in Computer Science*, pp. 402-414, 1999.
 - [6] A. Beimel, Y. Ishai, and T. Malkin. Reducing the Servers Computation in Private Information Retrieval: PIR with Preprocessing. *CRYPTO 2000, vol. 1880 of Lecture Notes in Computer Science*, pp. 56-74, 2000. Journal version to appear in *Journal of Cryptology* [Updated June 2003].
 - [7] Yael Gertner, Shafi Goldwasser, and Tal Malkin. A Random Server Model for PIR. *RANDOM 98, vol. 1518 of Lecture Notes in Computer Science*, pp. 200-217, 1998.
 - [8] M. R. Garey and D. S. Johnson. Computers and Intractability: A Guide to the Theory of NP-Completeness. *W.H. Freeman Co., San Francisco*, 1976.
 - [9] B. Chor and N. Gilboa. Computationally private information retrieval. *Proc. of 29th STOC*, 1997.
 - [10] Erica Y. Yang, Jie Xu and Keith H. Bennett. Private Information Retrieval in the Presence of Malicious Failures. *Proceedings of the 26 th IEEE Annual International Computer Software and Applications Conference (COMPSAC '02)*, 0730-3157/02.
 - [11] Erica Y. Yang, Jie Xu and Keith H. Bennett. A Fault-Tolerant Approach to Secure Private Retrieval. *IEEE 2002*, 1060-9857/02, pp. 12~21.
 - [12] Dmitri Asonov. Private Information Retrieval - An overview and current trends. *Proceedings of the ECDPvA Workshop, Informatik 2001, Vienna, Austria, September 2001*.